

MCCoE CYBERSECURITY APPRENTICESHIP PROGRAM
PROJECT 4 OF 8 — PART 2: FRAMEWORKS + EXECUTIVE SUMMARY
COLONIAL PIPELINE RANSOMWARE (2021)

Ransomware · No MFA · East Coast Fuel Crisis · \$4.4M Ransom Paid

THIS PROJECT: Apply the NIST CSF and pentesting methodology. Write and present your professional Executive Summary. This project ends with your Executive Summary submission (100 points).

PROJECT 4 · DAY 6	MONDAY — NIST CSF — DEFENSIVE FAILURE ANALYSIS	1-2 HRS
-------------------	--	---------

OBJECTIVE: Students apply all 5 NIST Cybersecurity Framework functions to identify exactly what the organization did wrong and what they should have done.

CLASS SCHEDULE

TIME	ACTIVITY	DETAIL / INSTRUCTIONS
0:00-0:20	Project Launch + Review	Quick recap of last project findings. Preview this project: today = defender perspective. What failed? What should have existed?
0:20-0:50	Lecture: NIST CSF	Teach the 5 functions. Draw a timeline on the board — overlay NIST. Show: Identify/Protect are BEFORE. Detect/Respond/Recover are DURING and AFTER.
0:50-1:40	NIST Failure Analysis	Students fill out the NIST table: for each function — specific failure + specific corrective action. No vague answers.
1:40-2:00	Critical Failure Vote	Which NIST function had the most catastrophic failure? Students vote and justify their answer. Discuss.

🎯 **OBJECTIVE:** Students map the attacker's actions to the 5 pentesting phases. Think like an attacker to become a better defender.

CLASS SCHEDULE

TIME	ACTIVITY	DETAIL / INSTRUCTIONS
0:00-0:30	Lecture: 5 Pentest Phases	Teach Reconnaissance, Scanning, Gaining Access, Maintaining Access, Covering Tracks. Why thinking like an attacker makes you a better defender.
0:30-1:10	Methodology Mapping	Students map the attacker's specific actions in this incident to each of the 5 phases. Include specific tools or techniques used.
1:10-1:40	Attacker vs Defender Game	For each phase: students suggest what the attacker did AND what a defender could have done to detect or stop it.
1:40-2:00	Homework Briefing	Assign: Tonight, outline your full Executive Summary using the template. Every section must have at least 3 bullet points before you write.

🎯 **OBJECTIVE:** Students develop and workshop 5 specific, actionable recommendations. Peer collaboration to pressure-test each recommendation.

CLASS SCHEDULE

TIME	ACTIVITY	DETAIL / INSTRUCTIONS
0:00-0:20	From Here On Out Review	Go through the "From Here On Out" section together. Discuss: are these the right priorities? Would you add anything?
0:20-1:00	Recommendations Workshop	Students draft their 5 recommendations with justification. Then pair up: each partner challenges one recommendation — is it specific enough? Does it address this incident?
1:00-1:30	Priority Debate	Class votes on the single most important recommendation. Each student defends their #1. Group builds a consensus top 5.
1:30-2:00	Executive Summary Drafting	

🎯 **OBJECTIVE:** Students complete peer review, deliver professional executive summary presentations, submit, and debrief the full incident.

CLASS SCHEDULE

TIME	ACTIVITY	DETAIL / INSTRUCTIONS
0:00-0:30	Writing + Peer Review	Students finalize all 9 sections of the Executive Summary. Swap with a partner: (1) strongest section, (2) one section needing more specifics, (3) one fact missed.
0:30-1:00	Revision Time	
1:00-1:45	Presentations + Submission	Each student presents 3-5 minutes. Collect completed Executive Summaries (100 pts). Class gives structured feedback: one strength, one specific improvement.
1:45-2:00	Full Debrief + Next Project Preview	What is the single most important lesson from this incident? What would you tell an IT team to do first thing Monday morning? Preview the next project.

NIST CSF FAILURE ANALYSIS REFERENCE

NIST FUNCTION	WHAT FAILED	WHAT SHOULD HAVE HAPPENED
Identify	FAILED — Did not know VPN credentials were exposed on the dark web; no dark web monitoring	Conduct regular asset inventories, vendor risk assessments, and map all third-party connections
Protect	FAILED — No MFA on VPN accounts; single password = full network access	Implement NIST SP 800-53 controls. Enforce MFA, patching SLAs, network segmentation
Detect	PARTIAL — Detected ransomware relatively quickly but 100GB was already exfiltrated	Deploy SIEM, IDS/IPS, behavioral analytics. Set up 24/7 monitoring with mandatory alert response SLAs
Respond	MIXED — Paid \$4.4M ransom quickly; shut down pipeline proactively (OT was not infected)	Develop and TEST an incident response plan. Establish clear escalation paths
Recover	PARTIAL — Pipeline restarted after 6 days; FBI recovered \$2.3M; MFA implemented post-incident	Implement and test backup/recovery. Define RTO and RPO. Conduct tabletop exercises regularly

ATTACKER METHODOLOGY — 5 PHASES REFERENCE

PHASE	WHAT THE ATTACKER DID IN THIS INCIDENT
Reconnaissance	Searched dark web markets and credential dumps for Colonial Pipeline employee VPN credentials
Scanning	After VPN access, used internal scanning tools to map Colonial's network
Gaining Access	Single VPN password, no MFA — immediate unrestricted access to corporate IT network
Maintaining Access	Moved laterally through the network over several days before deploying ransomware
Covering Tracks	Deleted shadow copies and backup catalogues to prevent recovery without paying ransom

"FROM HERE ON OUT" — RECOMMENDATIONS REFERENCE

🔗 **NOTE:** These are the controls that, if in place, would have prevented or significantly reduced this breach.

- **MANDATE:** MFA on 100% of remote access systems — VPN, RDP, cloud portals, everything, no exceptions
- **MANDATE:** Dark web monitoring — continuously check if employee credentials appear in breach databases
- **MANDATE:** OT/IT complete network separation — pipeline controls must never share a network with business IT
- **IMPLEMENT:** Offline, air-gapped backups — ransomware cannot encrypt what it cannot reach
- **IMPLEMENT:** Incident response plan specific to ransomware — tested with tabletop exercises annually
- **CONSIDER:** Cyber insurance review — ensure policy covers ransomware payments and business interruption

REFERENCES & RESOURCES

- CISA Alert AA21-131A: "DarkSide Ransomware: Best Practices" — [cisa.gov](https://www.cisa.gov)
- U.S. Senate Homeland Security Committee: Colonial Pipeline CEO Testimony (June 8, 2021)
- DOJ Press Release: "Department of Justice Seizes \$2.3 Million in Cryptocurrency Paid to DarkSide" (June 7, 2021)
- TSA Pipeline Security Directive SD-02B — [tsa.gov](https://www.tsa.gov)
- MITRE ATT&CK: attack.mitre.org — search T1078, T1486, T1490
- CISA Ransomware Guide: [cisa.gov/ransomware](https://www.cisa.gov/ransomware)